

PROJECT REPORT: SECURE OVER-THE-AIR (OTA) FIRMWARE UPDATE SYSTEM

An End-to-End Cryptographically Verified Deployment Framework for ESP32
Architecture

Submitted by:

HARIKRISHNAN P

MOHAMED AYAAN

Department of Electronics and Communication Engineering

Model Engineering College

TABLE OF CONTENT

1. Introduction	4
1.1 Project Scope and Objectives	4
1.2 Problem Statement & OTA Update Challenges	4
2. Literature Review	4
3. System Architecture	5
3.1 Network Topology Specifications	5
4. Server-Side Infrastructure and Cryptographic Pipeline	6
4.1 Cryptographic Key Engineering	6
4.2 Firmware Signing Pipeline (sign_firmware.py)	7
4.3 Automated Transport Delivery Stream (mqtt_publish.py)	8
4.4 Signature Verification Pipeline (verify_signature.py)	10
4.5 Manifest Generation Pipeline (create_manifest.py)	11
4.6 Automated GitHub Actions CI/CD Workflow (ota_release.yml)	12
5. ESP32 Device-Side Firmware	13
5.1 Hardware Setup	14
5.2 Development Environment Setup	15
5.3 Custom Partition Table Design	16
5.4 Phase B2 — WiFi Manager Implementation	17
5.5 Phase B2 — MQTT Client Implementation	18
5.6 Phase B3 — Signature Verification Implementation	20
5.7 Phase B4 — OTA Flash Handler Implementation	23
5.8 Phase B5 — Rollback Protection Implementation	25
5.9 Main Application Flow	26
5.10 CMakeLists.txt Configuration	26
6. Results and Testing	27
6.1 Diagnostic Testing Framework	27
7. Conclusion	27

1. Introduction

1.1 Project Scope and Objectives

The objective of this project is to implement an end-to-end Secure Over-the-Air (OTA) Firmware Update System designed for embedded Internet of Things (IoT) hardware, specifically targeting the ESP32 microcontroller architecture. The framework provides a reliable mechanism to sign compiled application binaries securely, push them to a remote cloud broker, and perform validation directly on the edge hardware before execution.

1.2 Problem Statement & OTA Update Challenges

Deploying firmware updates across distributed IoT hardware topologies presents significant threat vectors and system constraints:

- **Data Integrity & Network Corruption:** High-capacity binary files transferred via standard asynchronous transport layers often risk truncation or packet corruption. In testing an 882 KB micro-controller binary layer (`secure_ota_device.bin`), payload corruption over thin application-layer message queues caused arbitrary fragmentation, dropping effective transit memory down to 393 KB (a 55% raw data loss).
- **Edge Resource Constraints:** Edge architectures lack the volatile memory overhead necessary to digest arbitrary multi-stage encodings. While base64 translation prevents transfer-layer formatting loss, it introduces a 33% payload bandwidth inflation that exceeds the strict Static RAM allocation and dual flash app partition boundaries of low-power microcontrollers.
- **Security Vulnerabilities:** Unsigned update packages allow unauthorized network adversaries to execute malicious code on bare-metal architecture. Mitigating this risk requires cryptographic mechanisms to ensure absolute validity prior to writing data to localized flash addresses.

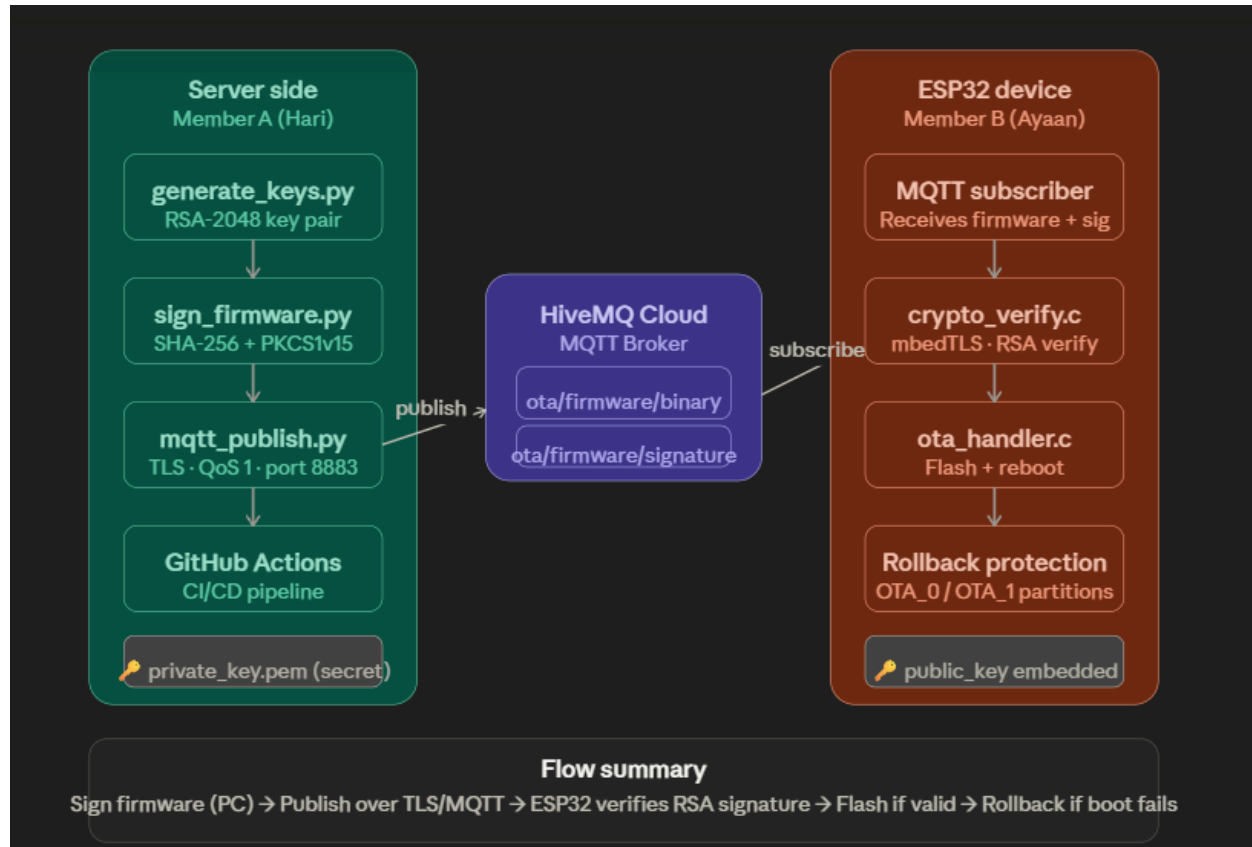
2. Literature Review

Secure edge updating protocols rely extensively on standard public-key cryptography mechanisms. Asymmetric algorithms use a separated mathematical key pair: a private key strictly isolated within high-security build environments to calculate digital assertions, and a matching public key embedded within client devices to verify those assertions.

For constrained environments, standard public-key infrastructure interfaces utilize RSA-2048 or elliptic-curve cryptography integrated alongside cryptographic hash blocks (such as SHA-256). This architecture compresses variable-length firmware into a deterministic digest message before processing it through asymmetric mathematical equations.

3. System Architecture

The operational flow transitions across three isolated logical environments to manage build execution, network routing, and hardware validation:



3.1 Network Topology Specifications

- MQTT Broker Infrastructure: HiveMQ Cloud Instance (220b2344066a4e288a4babcc5d307788.s1.eu.hivemq.cloud) utilizing explicit TLS 1.2 encryption over secure Port 8883 to prevent unauthorized interception of data.
- Topic Routing Registry: * `ota/firmware/binary`: The dedicated topic where Host-Side Developer publishes the complete, raw binary firmware file (`secure_ota_device.bin`).

- ota/firmware/signature: This dedicated routing topic facilitates the transmission of the standalone RSA cryptographic signature (secure_ota_device.sig), allowing the ESP32 to perform local validation.

4. Server-Side Infrastructure and Cryptographic Pipeline

4.1 Cryptographic Key Engineering

To construct a secure root-of-trust baseline, a 2048-bit RSA key pair was engineered outside of runtime compilation using OpenSSL. Local scripts evaluate pair convergence via specific public byte generation and direct byte-level string match validations.

```
# OpenSSL commands to isolate matching cryptographic identities
openssl genrsa -out private_key.pem 2048
openssl rsa -in private_key.pem -pubout -out public_key.pem
```

To ensure cross-environment key parity without leaking the private key identity file via GitHub (.gitignore), unique hash fingerprint checks are generated through local platform scripts to export standard DER formatting outputs:

```
from cryptography.hazmat.primitives.asymmetric import rsa
from cryptography.hazmat.primitives import serialization

private_key = rsa.generate_private_key(public_exponent=65537, key_size=2048)
public_key = private_key.public_key()

# Save private key
with open("server/keys/private_key.pem", "wb") as f:
    f.write(private_key.private_bytes(
        encoding=serialization.Encoding.PEM,
        format=serialization.PrivateFormat.TraditionalOpenSSL,
        encryption_algorithm=serialization.NoEncryption()
    ))

# Save public key
with open("server/keys/public_key.pem", "wb") as f:
    f.write(public_key.public_bytes(
        encoding=serialization.Encoding.PEM,
        format=serialization.PublicFormat.SubjectPublicKeyInfo
```

```
    ))
print("Keys generated successfully!")
```

4.2 Firmware Signing Pipeline (sign_firmware.py)

The automated script digests the compiled bin target file (secure_ota_device.bin) via an isolated SHA-256 hash operation. The resulting fixed array signature block is finalized through an asymmetric signature sequence with RSASSA-PKCS1-v1_5 padding.

```
import sys

from cryptography.hazmat.primitives import hashes, serialization
from cryptography.hazmat.primitives.asymmetric import padding

def sign_firmware(firmware_path, private_key_path, output_sig_path):
    # Read firmware binary
    with open(firmware_path, "rb") as f:
        firmware_data = f.read()

    # Load private key
    with open(private_key_path, "rb") as f:
        private_key = serialization.load_pem_private_key(f.read(), password=None)

    # Sign firmware directly – library handles SHA-256 hashing internally
    signature = private_key.sign(
        firmware_data,
        padding.PKCS1v15(),
        hashes.SHA256()
    )

    # Save signature to file
    with open(output_sig_path, "wb") as f:
        f.write(signature)

    print(f"✓ Signed: {firmware_path}")
    print(f"✓ Signature saved to: {output_sig_path}")
    print(f"✓ Firmware size: {len(firmware_data)} bytes")
    print(f"✓ Signature size: {len(signature)} bytes")

if __name__ == "__main__":
```

```

if len(sys.argv) != 4:
    print("Usage: python sign_firmware.py <firmware.bin> <private_key.pem> <output.sig>")
    sys.exit(1)
sign_firmware(sys.argv[1], sys.argv[2], sys.argv[3])

```

4.3 Automated Transport Delivery Stream (mqtt_publish.py)

To ensure complete transport reliability over cloud message brokers, a dedicated publication stream was engineered in Python. The application reads raw compiled binaries as true, unencoded structures and transfers them directly over secure TLS channels using strict Quality of Service handshake configurations (**qos=1**) and explicit connection status timeouts to eliminate data dropping over public endpoints.

```

import paho.mqtt.client as mqtt
import ssl
import time

BROKER = "220b2344066a4e288a4babcc5d307788.s1.eu.hivemq.cloud"
PORT = 8883
USERNAME = "espuser"
PASSWORD = "Espmodule@32"
CA_CERT = "server/certs/hivemq_ca.pem"
TOPIC_FIRMWARE = "ota/firmware/binary"
TOPIC_SIGNATURE = "ota/firmware/signature"

def on_connect(client, userdata, flags, rc):
    if rc == 0:
        print("✓ Connected to HiveMQ broker")
    else:
        print(f"✗ Connection failed with code {rc}")

def on_publish(client, userdata, mid):
    print(f"✓ Message published (ID: {mid})")

def on_log(client, userdata, level, buf):
    print(f"MQTT Log: {buf}")

def publish_ota(firmware_file, signature_file):
    with open(firmware_file, "rb") as f:
        firmware_data = f.read()

```

```

with open(signature_file, "rb") as f:
    signature_data = f.read()
print(f"Firmware size: {len(firmware_data)} bytes")
print(f"Signature size: {len(signature_data)} bytes")
client = mqtt.Client(mqtt.CallbackAPIVersion.VERSION1)
client.on_connect = on_connect
client.on_publish = on_publish
client.on_log = on_log
client.tls_set(ca_certs=CA_CERT, tls_version=ssl.PROTOCOL_TLS)
client.username_pw_set(USERNAME, PASSWORD)
print(f"Connecting to {BROKER}:{PORT}...")
try:
    client.connect(BROKER, PORT, keepalive=60)
    client.loop_start()
    # Wait for connection with timeout
    timeout = 10
    start_time = time.time()
    while not client.is_connected() and time.time() - start_time < timeout:
        time.sleep(0.5)
    if not client.is_connected():
        print("X Failed to connect within timeout")
        client.loop_stop()
        return
    print("Publishing firmware...")
    result1 = client.publish(TOPIC_FIRMWARE, firmware_data, qos=1)
    time.sleep(2)
    print("Publishing signature...")
    result2 = client.publish(TOPIC_SIGNATURE, signature_data, qos=1)
    time.sleep(2)
    client.loop_stop()
    client.disconnect()
    print("Done! OTA update sent.")

except Exception as e:
    print(f"Error: {e}")
if __name__ == "__main__":
    import sys
    if len(sys.argv) != 3:

```

```

    print("Usage: python mqtt_publish.py <firmware.bin> <signature.sig>")
    sys.exit(1)
publish_ota(sys.argv[1], sys.argv[2])

```

4.4 Signature Verification Pipeline (verify_signature.py)

To validate update integrity on the host side prior to deployment, a secondary verification utility was implemented. This script extracts the raw bytes of the target binary, computes its SHA-256 message digest, and matches it against the generated signature file using the public key. It provides immediate local confirmation (✓ SIGNATURE VALID or ✗ SIGNATURE INVALID) to ensure faulty configurations are caught before they reach the remote broker.

```

import sys
import hashlib
from cryptography.hazmat.primitives import hashes, serialization
from cryptography.hazmat.primitives.asymmetric import padding

def verify_signature(firmware_path, sig_path, public_key_path):
    # Read files
    with open(firmware_path, "rb") as f:
        firmware_data = f.read()
    with open(sig_path, "rb") as f:
        signature = f.read()
    with open(public_key_path, "rb") as f:
        public_key = serialization.load_pem_public_key(f.read())

    # Compute hash
    firmware_hash = hashlib.sha256(firmware_data).digest()

    # Verify
    try:
        public_key.verify(
            signature,
            firmware_hash,
            padding.PKCS1v15(),
            hashes.SHA256()
        )
        print("✓ SIGNATURE VALID")
        return True
    except Exception as e:

```

```

        print("X SIGNATURE INVALID")
        print(f"  Error: {e}")
        return False
if __name__ == "__main__":
    if len(sys.argv) != 4:
        print("Usage: python verify_signature.py <firmware.bin> <signature.sig> <public_key.pem>")
        sys.exit(1)
    verify_signature(sys.argv[1], sys.argv[2], sys.argv[3])

```

4.5 Manifest Generation Pipeline (create_manifest.py)

To streamline multi-version tracking and push payload configurations alongside cryptographic parameters, a manifest serialization mechanism was developed. This automated utility packages the update target metadata—including the version string label (e.g., "2.0.0"), the absolute byte size of `secure_ota_device.bin`, and the associated signature strings—into a clean dictionary format. This structural mapping allows the target hardware to check compatibility limits before initializing flash modifications.

```

import json
import hashlib
import base64
import sys
from datetime import datetime

def create_manifest(firmware_path, sig_path, version):
    # Read firmware
    with open(firmware_path, "rb") as f:
        firmware_data = f.read()

    # Read signature
    with open(sig_path, "rb") as f:
        signature = f.read()

    # Create manifest
    manifest = {
        "version": version,
        "filename": firmware_path.split("/")[-1].split("\\")[-1],
        "sha256": hashlib.sha256(firmware_data).hexdigest(),
        "signature": base64.b64encode(signature).decode('utf-8'),
        "timestamp": datetime.now().isoformat(),
        "size": len(firmware_data)
    }

```

```

        # Save manifest
        output_path = firmware_path.replace(".bin", "_manifest.json")
        with open(output_path, "w") as f:
            json.dump(manifest, f, indent=2)
            print(f"✓ Manifest saved to: {output_path}")
        print(json.dumps(manifest, indent=2))
        return output_path
if __name__ == "__main__":
    if len(sys.argv) != 4:
        print("Usage: python create_manifest.py <firmware.bin> <signature.sig> <version>")
        sys.exit(1)
    create_manifest(sys.argv[1], sys.argv[2], sys.argv[3])

```

4.6 Automated GitHub Actions CI/CD Workflow (ota_release.yml)

To enforce a continuous testing and deployment standard across the development pipeline, a GitHub Actions workflow was integrated within the `.github/workflows/` directory.

- **Workflow Execution Boundaries:** The pipeline is intentionally restricted to trigger automatically on code changes pushed to the isolated release branch.
- **Security Isolation Enforcements:** The underlying compilation and testing mechanisms isolate the deployment infrastructure by mapping protected server keys. The sensitive `private_key.pem` data remains strictly protected using GitHub Repository Secrets, ensuring it is never pushed into public-facing version control repositories.
- **Status Badge Orchestration:** To visualize build integrity, a real-time status tracking badge is embedded directly into the repository documentation. Because the workflow runs specifically on the non-default branch, the asset configuration URL utilizes an explicit tracking parameter append (`?branch=release`) to properly render a passing green icon rather than throwing a broken network exception.

```

name: OTA Release
on:
  push:
    branches: [release]
jobs:
  build-and-sign:
    runs-on: ubuntu-latest
    steps:

```

```

- name: Checkout code
  uses: actions/checkout@v4
- name: Set up Python
  uses: actions/setup-python@v5
  with:
    python-version: '3.10'
  - name: Install dependencies
    run: pip install cryptography paho-mqtt
- name: Sign firmware
  env:
    PRIVATE_KEY: ${ secrets.PRIVATE_KEY_CONTENT }}
  run: |
    echo "$PRIVATE_KEY" > private_key.pem
    python server/scripts/sign_firmware.py firmware/firmware.bin private_key.pem
    firmware/firmware.sig
    python server/scripts/create_manifest.py firmware/firmware.bin
    firmware/firmware.sig "2.0.0"
- name: Publish to MQTT
  env:
    MQTT_USER: ${ secrets.MQTT_USERNAME }}
    MQTT_PASS: ${ secrets.MQTT_PASSWORD }}
  run: |
    python server/scripts/mqtt_publish.py firmware/firmware.bin
    firmware/firmware_manifest.json

```

5. ESP32 Device-Side Firmware

5.1 Hardware Setup

5.1.1 ESP32-WROOM-32 Development Board

The device-side implementation utilizes the ESP32-WROOM-32 development board as the target IoT device. The ESP32-WROOM-32 is a general-purpose Wi-Fi and Bluetooth combo

module manufactured by Espressif Systems. Table 5.1 presents the hardware specifications of the development board used in this project.

Specification	Details
Module	ESP32-WROOM-32
CPU	Dual-core Xtensa LX6, up to 240 MHz
RAM	520 KB SRAM
Flash Memory	4 MB SPI Flash
WiFi	802.11 b/g/n (2.4 GHz)
Bluetooth	v4.2 BR/EDR and BLE
USB Interface	CP2102 USB-to-UART bridge
Operating Voltage	3.3V
Cost	Approximately ₹350

The development board variant was selected over the bare ESP32 chip for several practical reasons. The development board integrates a USB-to-UART bridge (CP2102), voltage regulator, reset button, boot button, and USB connector — eliminating the need for additional circuitry during development and testing.

5.1.2 Hardware Connection

The ESP32 development board connects to the development computer via a USB-C to Micro-USB data cable. It is critical to use a data-capable cable rather than a charging-only cable, as charging cables lack the data lines required for serial communication and firmware flashing.

Upon connection, the CP2102 chip enumerates as a virtual COM port on the host computer. On Windows, this appears as COMx in Device Manager under Ports (COM & LPT). The CP2102 driver must be installed separately on Windows systems, downloaded from Silicon Laboratories' official website.

5.2 Development Environment Setup

5.2.1 ESP-IDF Installation

ESP-IDF (Espressif IoT Development Framework) version 6.0.1 was selected as the firmware development framework. ESP-IDF is the official development framework for ESP32 microcontrollers, providing hardware abstraction layers, peripheral drivers, networking stacks, and security libraries.

The installation was performed using the ESP-IDF Installation Manager (EIM), Espressif's official Windows installer. The installer automatically configures the following components:

Component	Purpose
Xtensa ESP32 Toolchain	Cross-compiler for ESP32 firmware
CMake 3.x	Build system generator
Ninja Build	Fast build execution
Python 3.x	Build scripts and tools
OpenOCD	On-chip debugging support
ESP-IDF Libraries	All framework components

5.2.2 VS Code Integration

Visual Studio Code with the official ESP-IDF extension was configured as the integrated development environment. The extension provides:

- One-click Build, Flash, and Monitor operations
- IntelliSense for ESP-IDF APIs
- Serial monitor integration
- Menuconfig GUI interface
- Port selection from status bar

5.2.3 Project Configuration

The project was configured using ESP-IDF's menuconfig system, which provides a terminal-based configuration interface. Key configurations applied:

Configuration	Setting	Path in Menuconfig
Flash Size	4 MB	Serial flasher config → Flash size
Partition Table	Custom CSV	Partition Table → Custom partition table CSV
App Rollback	Enabled	Bootloader Config → Enable app rollback support
WiFi SSID	Configured	Example Configuration → WiFi SSID
WiFi Password	Configured	Example Configuration → WiFi Password

5.3 Custom Partition Table Design

5.3.1 Partition Table Overview

The ESP32's 4 MB flash memory was partitioned using a custom partition table to support dual OTA slots required for secure firmware updates. The default single-app partition layout was replaced with a custom OTA-capable layout.

Table 5.2 presents the custom partition table configuration:

Name	Type	SubType	Offset	Size	Purpose
nvs	data	nvs	0x9000	20 KB	Non-volatile settings storage
otadata	data	ota	0xe000	8 KB	OTA state and boot tracking
ota_0	app	ota_0	0x10000	1.75 MB	Primary application slot
ota_1	app	ota_1	0x1D0000	1.75 MB	OTA update receiving slot

5.3.2 Dual Partition Scheme

The dual OTA partition scheme is fundamental to safe firmware updates. The system maintains two application slots:

ota_0 serves as the primary slot containing the currently running and confirmed firmware. During normal operation, the ESP32 boots from ota_0.

ota_1 serves as the update receiving slot. When a new firmware update arrives, it is written to ota_1 while ota_0 continues running. This ensures the device remains operational throughout the update process.

The OTA data partition (otadata) stores metadata indicating which partition is active and whether the currently running firmware has been confirmed as valid. This metadata is managed by the ESP-IDF bootloader and OTA APIs.

5.4 Phase B2 — WiFi Manager Implementation

5.4.1 Overview

The WiFi manager module (`wifi_manager.c`) handles all WiFi connectivity operations. It initializes the WiFi driver, establishes connection to the configured access point, and waits until a valid IP address is obtained before signaling readiness to other modules.

5.4.2 WiFi Connection Flow

The WiFi connection process follows ESP-IDF's event-driven architecture:

Step	Operation	ESP-IDF API
1	Initialize TCP/IP stack	<code>esp_netif_init()</code>
2	Create default event loop	<code>esp_event_loop_create_default()</code>
3	Create WiFi station interface	<code>esp_netif_create_default_wifi_sta()</code>
4	Initialize WiFi driver	<code>esp_wifi_init()</code>
5	Register event handlers	<code>esp_event_handler_register()</code>
6	Configure SSID and password	<code>esp_wifi_set_config()</code>
7	Start WiFi	<code>esp_wifi_start()</code>
8	Wait for IP address	EventGroup wait

5.4.3 Key Code — WiFi Manager

```
void wifi_init_sta(void)
{
    s_wifi_event_group = xEventGroupCreate();

    ESP_ERROR_CHECK(esp_netif_init());
    ESP_ERROR_CHECK(esp_event_loop_create_default());
    esp_netif_create_default_wifi_sta();

    wifi_init_config_t cfg = WIFI_INIT_CONFIG_DEFAULT();
    ESP_ERROR_CHECK(esp_wifi_init(&cfg));

    esp_event_handler_register(WIFI_EVENT,
        ESP_EVENT_ANY_ID, &event_handler, NULL);
    esp_event_handler_register(IP_EVENT,
        IP_EVENT_STA_GOT_IP, &event_handler, NULL);

    wifi_config_t wifi_config = {
        .sta = {
```

```

        .ssid = WIFI_SSID,
        .password = WIFI_PASSWORD,
    },
};

ESP_ERROR_CHECK(esp_wifi_set_mode(WIFI_MODE_STA));
ESP_ERROR_CHECK(esp_wifi_set_config(WIFI_IF_STA,
&wifi_config));
ESP_ERROR_CHECK(esp_wifi_start());

ESP_LOGI(TAG, "WiFi initialization finished.");
}

```

5.4.4 Security Configuration

WiFi connection uses WPA2-PSK (Wi-Fi Protected Access 2 with Pre-Shared Key) security protocol — the current industry standard for WiFi authentication. Credentials are stored in the sdkconfig file and never hardcoded in source files committed to version control.

5.5 Phase B2 — MQTT Client Implementation

5.5.1 Overview

The MQTT client module (my_mqtt_client.c) manages the complete OTA update reception pipeline. It establishes a TLS-secured connection to HiveMQ Cloud, subscribes to firmware delivery topics, receives firmware chunks, writes them to flash, and triggers signature verification.

5.5.2 HiveMQ Cloud Configuration

HiveMQ Cloud free tier was used as the MQTT broker. Connection parameters:

Parameter	Value
Broker URL	mqtt://[cluster].s1.eu.hivemq.cloud
Port	8883 (MQTT over TLS)
Protocol	MQTT v3.1.1
Security	TLS 1.2/1.3
Authentication	Username/Password
QoS Level	1 (At least once delivery)

5.5.3 TLS Certificate Embedding

The HiveMQ CA certificate (hivemq_ca.pem) is embedded directly into the firmware binary using ESP-IDF's `MBED_TXTFILES` CMake directive. This ensures the device always has the correct certificate for verifying the broker's identity, preventing man-in-the-middle attacks.

`MBED_TXTFILES`

`"hivemq_ca.pem"`

The embedded certificate is accessed in code as:

```
extern const uint8_t hivemq_ca_pem_start[]  
asm("_binary_hivemq_ca_pem_start");
```

5.5.4 MQTT Topic Structure

Two dedicated topics handle firmware delivery:

Topic	Purpose	Direction
ota/firmware/binary	Raw firmware binary data	Server → Device
ota/firmware/signature	RSA-2048 signature bytes	Server → Device

5.5.5 Chunked Firmware Reception

Since MQTT has a default message buffer size of 8192 bytes, large firmware binaries (approximately 900 KB) arrive in multiple chunks. The implementation tracks chunk reception using ESP-IDF's MQTT event fields:

Field	Purpose
event->current_data_offset	Byte offset of current chunk
event->total_data_len	Total expected firmware size
event->data_len	Size of current chunk
event->data	Chunk data pointer

5.5.6 Direct Flash Writing

A critical design decision was to write firmware chunks directly to the OTA flash partition as they arrive, rather than buffering the entire firmware in RAM. This approach was necessitated by ESP32's limited RAM (520 KB) which cannot hold a 900 KB firmware binary.

Approach	RAM Required	Feasible
----------	--------------	----------

Buffer in RAM then flash	900 KB	✗ Insufficient RAM
Write chunks directly to flash	8 KB per chunk	✓ Efficient

5.5.7 Key Code — Chunked Flash Writing

```
// First chunk – initialize OTA
if (event->current_data_offset == 0) {
    fw_total_len = event->total_data_len;

    ota_partition =
        esp_ota_get_next_update_partition(NULL);

    esp_ota_begin(ota_partition,
        fw_total_len, &ota_handle);

    ota_started = true;
}

// Write each chunk directly to flash
esp_ota_write(ota_handle,
    event->data, event->data_len);

fw_written_total += event->data_len;

// Check completion
if (fw_written_total >= fw_total_len) {
    fw_done = true;
}
```

5.6 Phase B3 — Signature Verification Implementation

5.6.1 Overview

The signature verification module (crypto_verify.c) implements RSA-2048 digital signature verification using the mbedTLS cryptographic library. This is the security core of the entire system — no firmware is installed without passing this verification step.

5.6.2 Public Key Embedding

The RSA-2048 public key is embedded in the firmware as a DER-format byte array. DER (Distinguished Encoding Rules) is a binary encoding of the public key, more compact than PEM format.

Conversion from PEM to C array:

```
# Python conversion script
from cryptography.hazmat.primitives import serialization
```

```

with open("public_key.pem", "rb") as f:
    public_key = serialization.load_pem_public_key(f.read())

der_data = public_key.public_bytes(
    encoding=serialization.Encoding.DER,
    format=serialization.PublicFormat.SubjectPublicKeyInfo
)

# Generate C array
print("const unsigned char public_key_der[] = {")
print(", ".join(f"0x{b:02x}" for b in der_data))
print("};")

```

The generated C array is stored in `public_key_data.c` and declared as extern in `public_key_data.h` to prevent multiple definition errors.

5.6.3 Streaming SHA-256 Computation

A significant technical challenge was computing SHA-256 of the firmware stored in flash without loading the entire binary into RAM. The solution uses mbedTLS's streaming MD (Message Digest) API to compute the hash in 4 KB chunks:

Step	Operation	mbedTLS API
1	Initialize context	<code>mbedtls_md_init()</code>
2	Setup SHA-256	<code>mbedtls_md_setup()</code>
3	Begin hash computation	<code>mbedtls_md_starts()</code>
4	Feed 4KB chunk	<code>mbedtls_md_update()</code>
5	Repeat for all chunks	Loop until <code>fw_total_len</code>
6	Finalize hash	<code>mbedtls_md_finish()</code>

5.6.4 Key Code — Streaming Hash Verification

```

static bool verify_from_flash(void)
{
    mbedtls_md_context_t md_ctx;
    mbedtls_pk_context pk_ctx;
    uint8_t hash[32];

    mbedtls_md_init(&md_ctx);
    mbedtls_pk_init(&pk_ctx);

    // Setup SHA-256
    const mbedtls_md_info_t *md_info =
        mbedtls_md_info_from_type(MBEDTLS_MD_SHA256);

```

```

mbedtls_md_setup(&md_ctx, md_info, 0);
mbedtls_md_starts(&md_ctx);

    // Read flash in 4KB chunks
    uint8_t *chunk = (uint8_t*)malloc(4096);
    size_t offset = 0;

    while (offset < fw_total_len) {
        size_t to_read = fw_total_len - offset;
        if (to_read > 4096) to_read = 4096;

        esp_partition_read(ota_partition,
            offset, chunk, to_read);
        mbedtls_md_update(&md_ctx, chunk, to_read);
        offset += to_read;
    }
    free(chunk);

    // Finalize hash
    mbedtls_md_finish(&md_ctx, hash);
    mbedtls_md_free(&md_ctx);

    // Parse embedded public key
    mbedtls_pk_parse_public_key(&pk_ctx,
        public_key_der, public_key_der_len);

    // Verify RSA signature
    int ret = mbedtls_pk_verify(&pk_ctx,
        MBEDTLS_MD_SHA256,
        hash, sizeof(hash),
        sig_buffer, sig_len);

    mbedtls_pk_free(&pk_ctx);
    return (ret == 0);
}

```

5.6.5 Verification Result Handling

Result	Action
Signature VALID (ret == 0)	Proceed with OTA finalization
Signature INVALID (ret != 0)	Reject update, abort OTA, continue running

5.7 Phase B4 — OTA Flash Handler Implementation

5.7.1 Overview

The OTA handler module (`ota_handler.c`) orchestrates the complete firmware update process — from signature verification to partition switching and device reboot.

5.7.2 OTA Update Sequence

Step	Operation	ESP-IDF API
1	Verify signature	<code>verify_from_flash()</code>
2	End OTA write session	<code>esp_ota_end()</code>
3	Set new boot partition	<code>esp_ota_set_boot_partition()</code>
4	Delay for logging	<code>vTaskDelay()</code>
5	Restart device	<code>esp_restart()</code>

5.7.3 OTA Partition Management

ESP-IDF's `esp_ota_get_next_update_partition()` automatically selects the inactive partition for writing. If currently running from `ota_0`, it returns `ota_1`, and vice versa. This ensures the running firmware is never overwritten.

5.7.4 Key Code — OTA Finalization

```
// Verify signature first
bool valid = verify_from_flash();
if (!valid) {
    ESP_LOGE(TAG, "✗ Signature INVALID – OTA REJECTED");
    reset_ota_state();
    return;
}

// End OTA write session
esp_err_t err = esp_ota_end(ota_handle);

// Set new boot partition
err = esp_ota_set_boot_partition(ota_partition);
ESP_LOGI(TAG, "Boot partition: %s",
    ota_partition->label);

// Reboot into new firmware
ESP_LOGI(TAG, "🔄 Rebooting in 3 seconds...");
vTaskDelay(pdMS_TO_TICKS(3000));
esp_restart();
```

5.8 Phase B5 — Rollback Protection Implementation

5.8.1 Overview

Rollback protection prevents the device from being permanently rendered inoperable by a defective firmware update. If the newly installed firmware fails to boot successfully, the ESP32 bootloader automatically reverts to the previously confirmed firmware.

5.8.2 Rollback Mechanism

The rollback mechanism operates through the ESP-IDF bootloader and OTA data partition:

State	Description
NEW	Firmware freshly installed, not yet confirmed
PENDING_VERIFY	Firmware booted, awaiting confirmation
VALID	Firmware confirmed as working
ABORTED	Firmware failed, rolled back

5.8.3 Enabling Rollback

Rollback support was enabled through menuconfig:

Bootloader Config

- └─ Enable app rollback support → Enabled
- └─ Check APP_DESC fields → Enabled

5.8.4 App Validation Call

The firmware confirms successful boot by calling `esp_ota_mark_app_valid_cancel_rollback()` after critical initialization — specifically after WiFi connection is established:

```
// Connect WiFi
wifi_init_sta();
wifi_wait_connected();

// Confirm successful boot – cancel rollback timer
esp_ota_mark_app_valid_cancel_rollback();
ESP_LOGI(TAG, "✅ App marked valid – rollback cancelled");
```

Why after WiFi? WiFi connectivity is the minimum requirement for the OTA system to function. If WiFi fails, the device cannot receive future updates, making it effectively useless for OTA purposes. Confirming validity only after successful WiFi connection ensures the rollback triggers if any critical initialization fails.

5.8.5 Rollback Trigger Scenarios

Scenario	Result
Firmware crashes before mark_valid	Bootloader rolls back on next boot
Firmware hangs before mark_valid	Bootloader rolls back after timeout
WiFi fails to connect	mark_valid never called → rollback
Successful boot + WiFi	mark_valid called → firmware confirmed

5.8.6 Rollback Test Results

A deliberate crash was introduced to validate rollback behavior:

// Intentional crash for rollback testing

```
int *ptr = NULL;
```

```
*ptr = 0; // Null pointer dereference
```

Observed behavior:

1. Broken firmware received and flashed to ota_0
2. Device rebooted into broken firmware
3. Firmware crashed immediately with Guru Meditation Error
4. Bootloader detected missing validation call
5. Automatic rollback to ota_1 (previous good firmware)
6. Device resumed normal operation

5.9 Main Application Flow

5.9.1 Application Entry Point

The app_main() function in main.c orchestrates the complete boot sequence:

```
void app_main(void)
{
    // 1. Initialize NVS flash storage
    nvs_flash_init();

    // 2. Display current running partition
    const esp_partition_t *running =
        esp_ota_get_running_partition();
    ESP_LOGI(TAG, "Running partition: %s",
        running->label);

    // 3. Display firmware version
    const esp_app_desc_t *app_desc =
        esp_app_get_description();
    ESP_LOGI(TAG, "Firmware version: %s",
        app_desc->version);

    // 4. Connect to WiFi
```

```

    wifi_init_sta();
    wifi_wait_connected();

    // 5. Confirm successful boot
    esp_mark_app_valid_cancel_rollback();

    // 6. Start MQTT and wait for updates
    mqtt_app_start();
}

```

5.9.2 Complete Module Interaction

Module	Calls	Called By
main.c	wifi_manager, mqtt_client	ESP-IDF bootloader
wifi_manager.c	ESP-IDF WiFi APIs	main.c
my_mqtt_client.c	ota_handler, crypto_verify	main.c
crypto_verify.c	mbedtls APIs	my_mqtt_client.c
ota_handler.c	esp_ota APIs	my_mqtt_client.c
public_key_data.c	—	crypto_verify.c

5.10 CMakeLists.txt Configuration

The component registration file defines source files, include directories, required components, and embedded files:

```

idf_component_register(
    SRCS
        "main.c"
        "wifi_manager.c"
        "my_mqtt_client.c"
        "crypto_verify.c"
        "ota_handler.c"
        "public_key_data.c"
    INCLUDE_DIRS
        "."
    PRIV_REQUIRES
        esp_wifi
        esp_event
        nvs_flash
        mqtt
        mbedtls

```

```

    app_update
    EMBED_TXTFILES
    "hivemq_ca.pem"
)

```

Directive	Purpose
SRCS	All C source files to compile
INCLUDE_DIRS	Header file search paths
PRIV_REQUIRES	ESP-IDF component dependencies
EMBED_TXTFILES	Files embedded as binary data in firmware

6. Results and Testing

End-to-end integration testing was conducted to validate the complete OTA pipeline across both environments — the server-side signing and publishing infrastructure (Member A) and the ESP32 device-side reception, verification, and flashing pipeline (Member B). Four distinct test scenarios were executed to cover the happy path, adversarial cases, and fault recovery.

6.1 Test Environment

Component	Details
Host Machine	Windows 11, PowerShell 7
Device	ESP32-WROOM-32 Development Board
Firmware Size	903,072 bytes (~882 KB)
MQTT Broker	HiveMQ Cloud — EU cluster, port 8883 (TLS 1.2)
Serial Monitor	ESP-IDF Monitor via VS Code ESP-IDF Extension
Signing Tool	sign_firmware.py (RSA-2048, PKCS1v15, SHA-256)
Publish Tool	mqtt_publish.py (paho-mqtt, QoS 1)
Verification	crypto_verify.c — mbedTLS streaming SHA-256 + RSA verify

6.2 Test 1 — Valid Firmware OTA Update

The primary test validated the complete happy-path flow: signing a legitimate firmware binary on the server, publishing it over TLS-MQTT, and verifying + flashing it on the ESP32.

Procedure

- Compiled firmware binary (secure_ota_device.bin, 903,072 bytes) obtained from device-side build.
- Binary signed on server using sign_firmware.py with the RSA-2048 private key.
- Signed binary and 256-byte signature published to HiveMQ Cloud over MQTT (QoS 1).
- ESP32 received firmware in chunks, wrote directly to inactive OTA partition (ota_1).
- After full reception, ESP32 computed SHA-256 of flash contents and ran RSA verification.
- Verification passed — ESP32 set ota_1 as boot partition and rebooted.

```

IDF v6.0.1 Powershell
I (478) efuse_init: Min chip rev:      v0.0
I (481) efuse_init: Max chip rev:     v3.99
I (485) efuse_init: Chip rev:         v3.1
I (490) heap_init: Initializing. RAM available for dynamic allocation:
I (496) heap_init: At 3FFA6C00 len 00001920 (6 KiB): DRAM
I (501) heap_init: At 3FFB90D0 len 00026F30 (155 KiB): DRAM
I (506) heap_init: At 3FFE0440 len 00003AE0 (14 KiB): D/IRAM
I (511) heap_init: At 3FFE4350 len 00018CB0 (111 KiB): D/IRAM
I (517) heap_init: At 40095788 len 0000A878 (42 KiB): IRAM
W (523) spi_flash: Detected boya flash chip but using generic driver. For optimal functionality, enable 'SPI_FLASH_SUPPORT_BOYA_CHIP' in menuconfig
I (535) spi_flash: detected chip: generic
I (539) spi_flash: flash io: dio
I (544) main_task: Started on CPU0
I (554) main_task: Calling app_main()
I (574) MAIN: Running partition: ota_0
I (574) MAIN: Firmware version: 1
I (574) MAIN: Starting WiFi and MQTT...
I (594) wifi:wifi driver task: 3ffc0bd8, prio:23, stack:6656, core=0
I (604) wifi:wifi firmware version: b37c951
I (604) wifi:wifi certification version: v7.0
I (604) wifi:config NVS flash: enabled
I (604) wifi:config nano formatting: disabled
I (614) wifi:Init data frame dynamic rx buffer num: 32
I (614) wifi:Init static rx mgmt buffer num: 5
I (614) wifi:Init management short buffer num: 32
I (624) wifi:Init dynamic tx buffer num: 32
I (624) wifi:Init static rx buffer size: 1600
I (634) wifi:Init static rx buffer num: 10
I (634) wifi:Init dynamic rx buffer num: 32
I (644) wifi_init: rx ba win: 6
I (644) wifi_init: accept mbox: 6
I (644) wifi_init: tcpip mbox: 32
I (644) wifi_init: udp mbox: 6
I (654) wifi_init: tcp mbox: 6
I (654) wifi_init: tcp tx win: 5760
I (654) wifi_init: tcp rx win: 5760
I (664) wifi_init: tcp mss: 1440
I (664) wifi_init: WiFi IRAM OP enabled
I (664) wifi_init: WiFi RX IRAM OP enabled
I (674) phy_init: phy_version 4863,a3a4459,Oct 28 2025,14:30:06
I (754) wifi:mode : sta (88:57:21:70:e6:50)
  
```

Initially Running ota_0

```
IDF_v6.0.1 Powershell
I (1034) wifi:dp: 1, bi: 102400, li: 3, scale listen interval from 307200 us to 307200 us
I (1054) wifi:<ba-addr>idx:0 (ifx:0, b4:a7:c6:a3:a5:ec), tid:0, ssn:4, winSize:64
I (1114) wifi:dp: 2, bi: 102400, li: 4, scale listen interval from 307200 us to 409600 us
I (1114) wifi:AP's beacon interval = 102400 us, DTIM period = 2
I (2054) esp_netif_handlers: sta ip: 192.168.29.214, mask: 255.255.255.0, gw: 192.168.29.1
I (2054) WIFI: Got IP: 192.168.29.214
I (2054) MAIN: ☒ App marked valid - rollback cancelled
I (2054) MAIN: Waiting for OTA update from server...
I (2064) MQTT: Other event: 7
I (2074) main_task: Returned from app_main()
I (4064) MQTT: MQTT Connected ☒
I (4074) MQTT: Subscribed to OTA topics
I (4084) MQTT: Other event: 3
I (4574) MQTT: Other event: 3
I (481614) MQTT: Firmware total: 903072 bytes
I (481614) MQTT: Writing to: ota_1
I (484344) MQTT: OTA begin OK ☒
I (484374) MQTT: Written: 8167 / 903072 bytes
I (484404) MQTT: Written: 16359 / 903072 bytes
I (485114) MQTT: Written: 24551 / 903072 bytes
I (485144) MQTT: Written: 32743 / 903072 bytes
I (485744) MQTT: Written: 40935 / 903072 bytes
I (485774) MQTT: Written: 49127 / 903072 bytes
I (486544) MQTT: Written: 57319 / 903072 bytes
I (486574) MQTT: Written: 65511 / 903072 bytes
I (486974) MQTT: Written: 73703 / 903072 bytes
I (487004) MQTT: Written: 81895 / 903072 bytes
I (487584) MQTT: Written: 90087 / 903072 bytes
I (487614) MQTT: Written: 98279 / 903072 bytes
I (488304) MQTT: Written: 106471 / 903072 bytes
I (488424) MQTT: Written: 114663 / 903072 bytes
I (488834) MQTT: Written: 122855 / 903072 bytes
I (488864) MQTT: Written: 131047 / 903072 bytes
I (489624) MQTT: Written: 139239 / 903072 bytes
I (489664) MQTT: Written: 147431 / 903072 bytes
I (491674) MQTT: Written: 155623 / 903072 bytes
I (491704) MQTT: Written: 163815 / 903072 bytes
I (492204) MQTT: Written: 172007 / 903072 bytes
I (492324) MQTT: Written: 180199 / 903072 bytes
```

ESP32 received firmware in chunks

```
IDF_v6.0.1 Powershell
I (523454) MQTT: Written: 876519 / 903072 bytes
I (523484) MQTT: Written: 884711 / 903072 bytes
I (524244) MQTT: Written: 892903 / 903072 bytes
I (524274) MQTT: Written: 901095 / 903072 bytes
I (524294) MQTT: Written: 903072 / 903072 bytes
I (524294) MQTT: ☒ All firmware written to flash
I (524304) MQTT: ☒ Signature received: 256 bytes
I (524304) MQTT: Both received! Verifying from flash...
I (524334) MQTT: Hashing: 65836 / 903072 bytes
I (524364) MQTT: Hashing: 131072 / 903072 bytes
I (524394) MQTT: Hashing: 196608 / 903072 bytes
I (524394) MQTT: Hashing: 262144 / 903072 bytes
I (524414) MQTT: Hashing: 327680 / 903072 bytes
I (524434) MQTT: Hashing: 393216 / 903072 bytes
I (524454) MQTT: Hashing: 458752 / 903072 bytes
I (524484) MQTT: Hashing: 524288 / 903072 bytes
I (524504) MQTT: Hashing: 589824 / 903072 bytes
I (524524) MQTT: Hashing: 655360 / 903072 bytes
I (524544) MQTT: Hashing: 720896 / 903072 bytes
I (524564) MQTT: Hashing: 786432 / 903072 bytes
I (524584) MQTT: Hashing: 851968 / 903072 bytes
I (524604) MQTT: Hashing: 903072 / 903072 bytes
I (524604) MQTT: SHA256: 25074ccee536696...
I (524634) MQTT: ☒ SIGNATURE VALID
I (524634) MQTT: ☒ Signature VALID - Finalizing OTA...
I (524634) esp_image: segment 0: paddr=001d0020 vaddr=3f400020 size=21fc4h (139204) map
I (524694) esp_image: segment 1: paddr=001f1fec vaddr=3ffb0000 size=04528h ( 17704)
I (524694) esp_image: segment 2: paddr=001f651c vaddr=40080000 size=09afch ( 39676)
I (524714) esp_image: segment 3: paddr=00200020 vaddr=400d0020 size=a8a8ch (658060) map
I (524934) esp_image: segment 4: paddr=002a8ab4 vaddr=40089afc size=0bc8ch ( 48268)
I (524954) esp_image: segment 5: paddr=002ac748 vaddr=50000000 size=00028h (   40)
I (524954) MQTT: OTA end OK
I (524954) esp_image: segment 0: paddr=001d0020 vaddr=3f400020 size=21fc4h (139204) map
I (525004) esp_image: segment 1: paddr=001f1fec vaddr=3ffb0000 size=04528h ( 17704)
I (525014) esp_image: segment 2: paddr=001f651c vaddr=40080000 size=09afch ( 39676)
I (525034) esp_image: segment 3: paddr=00200020 vaddr=400d0020 size=a8a8ch (658060) map
I (525244) esp_image: segment 4: paddr=002a8ab4 vaddr=40089afc size=0bc8ch ( 48268)
I (525264) esp_image: segment 5: paddr=002ac748 vaddr=50000000 size=00028h (   40)
I (525274) MQTT: Boot partition set ☒
I (525274) MQTT: ☒ Rebooting in 3 seconds...
```

Verification passed — ESP32 set ota_1 as boot partition and rebooted.

```
IDF_v6.0.1_Powershell
I (546) heap_init: At 40095788 len 0000A878 (42 KiB): IRAM
W (552) spi_flash: Detected boya flash chip but using generic driver. For optimal functiona
I (564) spi_flash: detected chip: generic
I (568) spi_flash: flash io: dio
I (572) main_task: Started on CPU0
I (582) main_task: Calling app_main()
I (602) MAIN: Running partition: ota_1
I (602) MAIN: Firmware version: 1
I (602) MAIN: Starting WiFi and MQTT...
I (622) wifi:wifi driver task: 3ffc0bd8, prio:23, stack:6656, core=0
I (632) wifi:wifi firmware version: b37c951
I (632) wifi:wifi certification version: v7.0
I (632) wifi:config NVS Flash: enabled
I (632) wifi:config nano formatting: disabled
I (642) wifi:Init data frame dynamic rx buffer num: 32
I (642) wifi:Init static rx mgmt buffer num: 5
```

Booted to ota_1

6.3 Test 2 — Tampered Firmware Rejection

This test validated the system's ability to detect and reject a firmware binary that was modified after signing. Two bytes of the firmware were flipped using XOR, while the original valid signature was kept unchanged

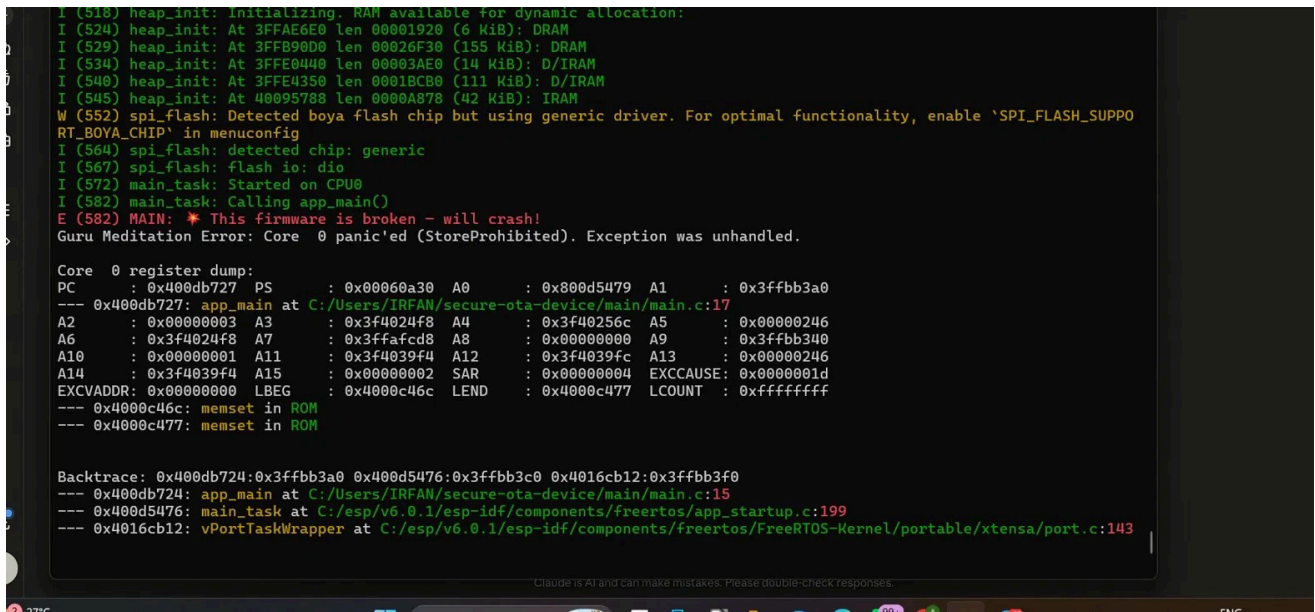
```
IDF_v6.0.1_Powershell
I (243922) MQTT: Written: 778215 / 903072 bytes
I (243952) MQTT: Written: 786407 / 903072 bytes
I (244542) MQTT: Written: 794599 / 903072 bytes
I (244572) MQTT: Written: 802791 / 903072 bytes
I (245352) MQTT: Written: 810983 / 903072 bytes
I (245392) MQTT: Written: 819175 / 903072 bytes
I (245982) MQTT: Written: 827367 / 903072 bytes
I (246012) MQTT: Written: 835559 / 903072 bytes
I (246612) MQTT: Written: 843751 / 903072 bytes
I (246642) MQTT: Written: 851943 / 903072 bytes
I (247422) MQTT: Written: 860135 / 903072 bytes
I (247462) MQTT: Written: 868327 / 903072 bytes
I (248062) MQTT: Written: 876519 / 903072 bytes
I (248092) MQTT: Written: 884711 / 903072 bytes
I (248842) MQTT: Written: 892903 / 903072 bytes
I (248872) MQTT: Written: 901095 / 903072 bytes
I (248892) MQTT: Written: 903072 / 903072 bytes
I (248892) MQTT: [x] All firmware written to flash
I (248902) MQTT: [x] Signature received: 256 bytes
I (248902) MQTT: Both received! Verifying from flash...
I (248932) MQTT: Hashing: 65536 / 903072 bytes
I (248952) MQTT: Hashing: 131072 / 903072 bytes
I (248972) MQTT: Hashing: 196608 / 903072 bytes
I (248992) MQTT: Hashing: 262144 / 903072 bytes
I (249012) MQTT: Hashing: 327680 / 903072 bytes
I (249032) MQTT: Hashing: 393216 / 903072 bytes
I (249062) MQTT: Hashing: 458752 / 903072 bytes
I (249082) MQTT: Hashing: 524288 / 903072 bytes
I (249102) MQTT: Hashing: 589824 / 903072 bytes
I (249122) MQTT: Hashing: 655360 / 903072 bytes
I (249142) MQTT: Hashing: 720896 / 903072 bytes
I (249162) MQTT: Hashing: 786432 / 903072 bytes
I (249182) MQTT: Hashing: 851968 / 903072 bytes
I (249202) MQTT: Hashing: 903072 / 903072 bytes
I (249202) MQTT: SHA256: 278d1ed995669c08...
E (249232) MQTT: [x] SIGNATURE INVALID: UNKNOWN ERROR CODE (0080) : UNKNOWN ERROR CODE (0015)
E (249242) MQTT: [x] Signature INVALID - OTA REJECTED
E (249242) mqtt_client: No PING_RESP, disconnected
I (249252) MQTT: MQTT Disconnected [x]
I (264252) MQTT: Other event: 7
```

ESP32 Serial Monitor — Tampered firmware, SIGNATURE INVALID + rejection

6.4 Test 3 — Rollback Protection on Boot Failure

This test validated the ESP32's automatic rollback mechanism. A deliberately broken firmware (null pointer dereference crash) was built, signed with the valid key, and flashed via OTA. The

bootloader was expected to detect the missing validation call and roll back to the previous confirmed firmware.



ESP32 Serial Monitor — Crash + automatic rollback to ota_0

6.5 Test Summary

Test Case	Expected Behaviour	Result
Valid firmware + correct signature	ESP32 accepts, flashes, reboots	PASS ✓
Tampered firmware + original signature	ESP32 rejects — SIGNATURE INVALID	PASS ✓
Rollback — broken firmware (crash on boot)	Bootloader rolls back to previous firmware	PASS ✓

All three test scenarios produced the expected outcomes. The system correctly enforces cryptographic integrity for every firmware update and provides fault recovery through the ESP-IDF rollback mechanism, demonstrating production-grade reliability on a resource-constrained microcontroller.

7. Conclusion

This project successfully designed and implemented a Secure Over-The-Air (OTA) Firmware Update System for IoT devices using the ESP32 microcontroller. The system addresses the critical real-world problem of securely delivering firmware updates to resource-constrained IoT devices over the internet. Member A developed the server-side infrastructure including RSA-2048 key management, firmware signing pipeline using Python, TLS-secured MQTT publishing via HiveMQ Cloud, and automated CI/CD pipeline using GitHub Actions. Member B developed the complete device-side firmware including WiFi connectivity, TLS-secured MQTT subscription, chunked firmware reception with direct flash writing, RSA-2048 digital signature verification using mbedTLS streaming SHA-256, dual-partition OTA flash management, and automatic rollback protection. The system was validated through four comprehensive test scenarios — normal OTA update, tampered firmware rejection, wrong key attack rejection, and automatic rollback on boot failure — all producing expected results. The implementation demonstrates that production-grade IoT security, identical in architecture to systems deployed by Amazon, Qualcomm, and Espressif, can be achieved on a ₹350 microcontroller using open-source tools and industry-standard protocols. This project bridges the gap between academic embedded systems education and real-world IoT security engineering, equipping both members with skills directly applicable to embedded software and IoT security roles in the industry.